What we enforce, what we measured, and what is not done yet.

For your IT and security reviewer. Every row names how it was checked. Nothing here has been tested by an outside party yet: it is our own code review, internal penetration test and automated tests (about 540 backend and 17 frontend).

THE DESIGN IN ONE PARAGRAPH

The model that reads untrusted text is quarantined: it has no tools, no memory between documents, and returns only typed fields (skills, dates, degree, languages). Code then checks every field against the visible text, a deterministic scorer ranks the candidates, a person approves every consequential action, and the executor refuses anything not approved. A fully manipulated model output can only choose values inside that schema, and each value must survive the check and a human. **The model is not the security boundary; the checks and the approval step are.**

CONTROLS IN PLACE

AREA	CONTROL	HOW CHECKED
Hostile CVs	Hidden text (white, tiny, off-page, under an image, zero-width, homoglyph, annotations, metadata) is found and shown to the reviewer; instruction-like text is flagged and never changes a score	40 of 40 found, 0 of 240 false alarms; 28 of 28 instruction payloads flagged
Hostile emails	The sender is verified by code from the mail headers; forged senders are held and receive no candidate data	15 of 15 spoofs contained
Uploads	PDF only, size and page limits, encrypted files refused; parsing runs in a separate worker with a deadline, so a hostile file cannot hang or crash the service	Automated tests, including deadline and crash cases
Runaway model	Every model call has a hard output limit (found and fixed during testing: one request had generated 39,000+ tokens)	Automated test; longest valid output about 650 tokens against a limit of 2,048
Approvals	Nobody approves an item they created; offers need distinct approvers; planted test items check reviewers are paying attention; an approved item runs once	Automated tests
Sessions and login	Hashed session tokens, HttpOnly SameSite=Strict cookies, idle and absolute expiry, CSRF check on every change, uniform login errors, account and network lockouts, scrypt password hashing at OWASP-equivalent cost	Automated tests; internal penetration test
Web hardening	Strict Content-Security-Policy without inline scripts, security headers, HSTS on HTTPS, request size caps, downloads as attachments	Automated tests
Production mode	`HG_ENV=production` refuses to start unless cookies are secure, API docs are off, origins are HTTPS, PDF isolation is on, and no cloud model is enabled without an explicit acknowledgement	Automated tests
Audit	Every sign-in, denial, approval and execution is logged in an append-only, hash-chained log with external timestamp anchors	Verification endpoint; automated tests
Dependencies	Pinned versions; vulnerability scan of backend dependencies reports no known issues (1 Nov 2026)	`pip-audit`; 2 moderate advisories remain in a front-end library

YOUR DATA

- The model runs on your own servers. A cloud model is off by default and is blocked in production unless you acknowledge it
- Identity details (town, school, gendered titles, emails) are masked before the model reads a CV
- Team views are aggregates, never per person; the question radar hides groups under 5 (the skills map shows holder

WHAT WE MEASURED

- Hidden-text attacks changed a result 3 of 40 times (naive screener 13 of 40)
- Plain-sight manipulation changed a result 7 of 14 times (naive screener 8 of 14): human review is the answer
- Same-CV-different-town/school/gender changed no score; changing only the CV's language changed 13 of 20
- All on synthetic CVs, attacks written by our team

counts, and small-team handling is still to be decided)
- No performance, productivity or stress scoring of employees

NOT DONE YET

Planned before a pilot	Multi-factor sign-in for HR managers and administrators; self-service password change
Your deployment	Data is not encrypted by the application: use disk encryption on the server. Automatic deletion after a role closes is not enforced yet
Planned	Pinning the model version by digest; tests of the email classifier against injected text; red-team tests that adapt to the model; an outside penetration test
Scope	Email sending and calendar booking are prepared for approval but delivery connectors are on the roadmap; CVs must be PDF

Measured 1 Nov 2026 with Qwen3-8B on one GPU. Details and open items are tracked in our security register and shared with you on request. Venidis supports your own review of GDPR, Law 2004-63 and the EU AI Act; this sheet is a description of controls, not a statement of legal compliance. [Contact: name · email]